



The governed agent platform on AWS

Governance is the product. Agents are add-ons.

Build the paved road once on AWS — every agent, model, and tool inherits identity, authorization, audit, compliance, hallucination control, and chargeback automatically.

THE PROBLEM

The pilot trap

A chatbot per department — each its own integration, security review, and audit. Spend nobody can attribute. No governed path from pilot to production.

~90%

of orgs piloting AI
[ANALYST/VENDOR tier]

~25%

reach funded production
[ANALYST/VENDOR tier]

**1 per
dept**

fragmented point-solutions
each re-does security & audit

The blocker is NOT the model.

It's identity, authorization, audit, data-class isolation, hallucination risk, cost control — and who has

authority to act

Every regulated buyer — government, education, healthcare, enterprise — has the same shape of problem with a different regime on top.

The agent isn't the product. The governance substrate is.

The trap mindset

- ✗ Buy/build a new agent per use case
- ✗ Re-do security review every time
- ✗ Re-architect identity, audit, cost each time
- ✗ The model is the deliverable

The Aegis mindset

- ✓ Build governance once as a paved road
- ✓ Every future agent inherits it automatically
- ✓ No re-architecture, no re-review per agent
- ✓ Governance is the deliverable; agents are add-ons

The moat is the governance, not the agent. Every new pack opens an industry; every new agent is sellable into every existing governed customer with zero governance rework.

WHAT AEGIS IS

Five layers. One paved road.



EDGE & IDENTITY

CloudFront + WAF + Shield · Cognito federates your IdP → short-lived verified JWT



CONTROL PLANE

The MCP authorization gateway — deny-by-default, least-privilege, human gate, scoped tokens, audit



REASONING

Model Gateway: Bedrock + mandatory Guardrails over PrivateLink · governed RAG grounding



DATA & EVIDENCE

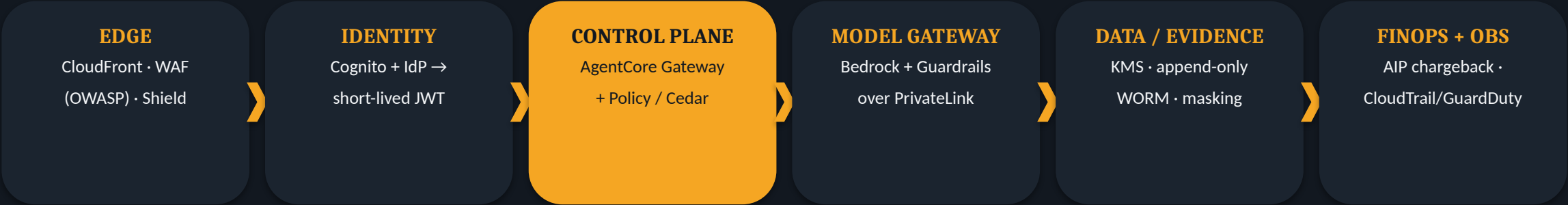
KMS CMK per data class · append-only audit · WORM · fail-closed masking · isolation



FINOPS & OBSERVABILITY

Token caps + per-department chargeback · CloudTrail / GuardDuty / Security Hub / Config

Edge → identity → control plane → model → data → FinOps



Edge: One managed perimeter inherited by every agent — no bespoke edge per agent.

Identity: Client-supplied roles never trusted; RS256 over IdP JWKS, alg-confusion guard.

Control plane: Every tool call brokered: ALLOW-iff predicate, human gate, OBO scoped token, audit.

Model gateway: Allowlist + prompt-pin + schema + grounding; inference stays in-account, no PII egress.

Data / evidence: KMS CMK per data class; append-only + WORM audit; masking fails closed.

FinOps / obs: Tagged application inference profiles → chargeback; full control-plane telemetry.

Multi-account landing zone (Control Tower): central governance account governs isolated workload accounts per data class — public · PII · PHI · CJI · FTI · EDU — each its own VPC, KMS CMK, WORM store.

ALLOW iff every clause holds

ALLOW iff:

```
authenticated_user is valid
AND agent grant permits the tool
AND user entitlement permits the tool
AND declared purpose is allowed
AND data-class boundary is satisfied
AND consent exists when required
AND residency boundary is satisfied
AND token / cost budget is available
AND a valid approval exists when required
# least-privilege = grant n entitlement
```



Consequential actions withheld in code

Issue / adjudicate / release / award / transfer are refused by the agent — proven absent by a test.



Bound, single-use human gate

Approval is bound to tool + args hash + purpose + requester + reviewer + expiry; separation of duties; replay rejected by conditional write.



OBO scoped per-call token

The gateway mints an on-behalf-of token so the agent acts AS the user for that one call — never a long-lived credential.

Five hard problems, solved once

1

Authorization

Deny-by-default gateway; least-privilege as grant n entitlement; agent can never exceed its human.

AC-3 • AC-6

2

Hallucination

Governed RAG + contextual grounding + automated reasoning (formal logic); decisions kept outside the LLM.

Confabulation

3

Audit

Append-only DynamoDB + S3 Object Lock WORM; fail-closed masking — survives a review board or FOIA.

AU-9 • AU-10

4

Cost

Hard token caps enforced before spend + per-department chargeback via tagged inference profiles.

Value chain

5

Onboarding

Signed manifest + 9-point minimum-bar CI gate — a documented bar any new agent must clear.

Manage

COMPLIANCE OVERLAY PACKS

One platform. Every regime.

The governance core is industry-agnostic. A pack switches on the right controls, regions, retention, masking entity sets, and guardrail policy — and ships an evidence map per control.

packs / slg

State, Local & Public Sector

GovRAMP (2025 scope: local gov, K-12, higher ed, hospitals) · CJIS v6.0 (MFA mandatory, audited since Oct 2025) · IRS Pub 1075 (FTI) · NIST AI RMF · ADA Title II

packs / education

K-12, Higher Ed & EdTech

FERPA · amended COPPA 2025 (biometric entities; opt-in consent; compliance Apr 2026) · SOPIPA / state laws · ADA / Section 508

packs / healthcare-lifesciences

Providers, Payers, Pharma & MedTech

HIPAA / HITECH (BAA required) · 42 CFR Part 2 · GxP / 21 CFR Part 11 (e-signature gate) · HITRUST · MARS-E

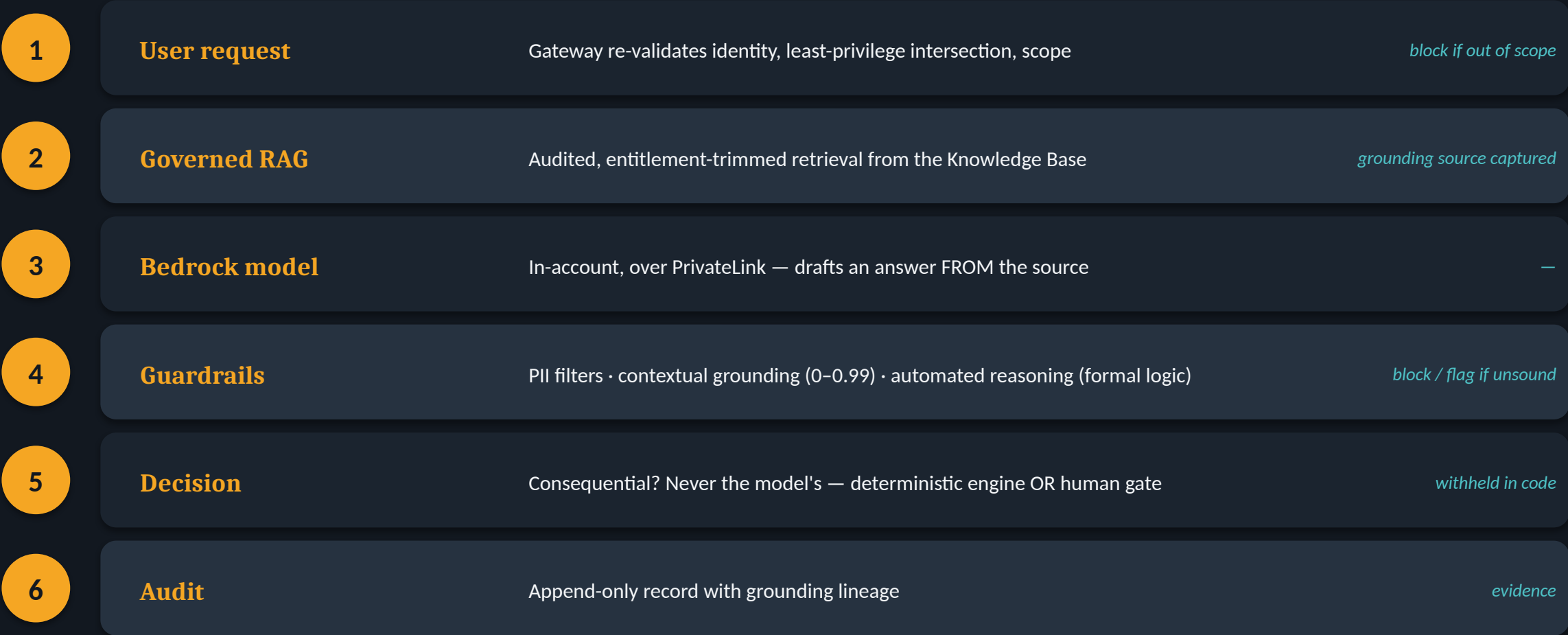
packs / enterprise

Cross-Industry / Whole-of-Enterprise

SOC 2 · PCI DSS (Luhn-aware card masking) · ISO 27001/27701 · GLBA · default-deny baseline

Packs compose by strictest-wins (union of masking sets, highest thresholds, narrowest isolation). A pack configures controls — it does not grant an authorization.

A layered trust pipeline



The model proposes; governed retrieval grounds it; guardrails validate it; deterministic logic or a human decides it; the audit records it.

Token caps before spend. Chargeback after.

"Token maxing"

One runaway agent or prompt burns the budget.

→ Hard token caps enforced IN THE GATEWAY, before spend occurs — fail-closed on budget, with a clear denial reason in the audit.

Chargeback

One department uses a model, another foots the bill.

→ Per-department attribution via Bedrock application inference profiles + cost-allocation tags → Cost Explorer / CUR. 100% of model spend tagged at source.

agent call → gateway (budget check) → AIP ARN (tagged dept/team/app) → Bedrock → billing record carries tags → Cost Explorer / CUR → chargeback

Tags: dept · team · app · data_class · pack. Call the model using the profile ARN in place of the model ID. The gateway token meter is the real-time control; the CUR is the financial truth (tags can lag up to 24h).

Easy to add agents once the platform is up

```
$ python3 tools/add_agent.py \
  --id billing-inquiry --owner dept-finance \
  --pack enterprise --blast-radius low
→ generates a schema-conformant agent package
→ validated against the manifest schema before writing
```

The scaffolder writes:

- **agent.manifest.yaml** scope · grants · budget · grounding · evals
- **prompts/system.md** pinned, hash-stable system prompt
- **evals/suite.md** accuracy · refusal · fairness · injection · a11y · grounding
- **runbook.md** · **README.md** day-2 ops + how it clears the bar

The 9-point minimum bar

- ✓ Signed, schema-valid manifest
- ✓ Declared scope, grants, data classes
- ✓ Token budget + cost owner
- ✓ Grounding threshold set
- ✓ Eval suite ≥ declared pass rate
- ✓ Refusal + prompt-injection tested
- ✓ Fairness / four-fifths checked
- ✓ Accessibility for public agents
- ✓ Registered tools only (no undeclared)

Ships now: service-desk-triage · resident-services-311

Package once. Deploy into any governed environment.

1

PLATFORM

Aegis core + packs

The governed paved road. Sold / deployed per environment. Identity, authz, audit, compliance, hallucination control, chargeback — all inherited.

2

ADD-ON AGENTS

Manifest-conformant

Packaged agents sold as products. Each inherits the customer's governance on deploy. Priced per agent / per seat / per usage.

3

WHY IT COMPOUNDS

The flywheel

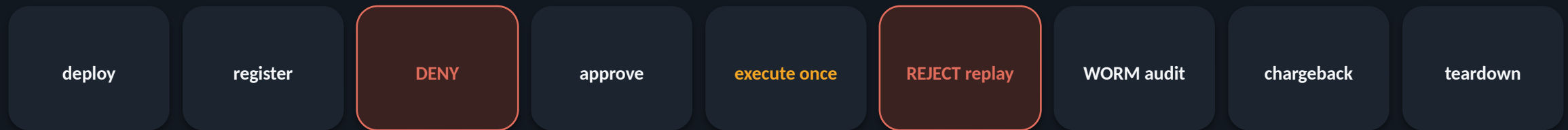
Every new pack opens an industry. Every new agent sells into every existing governed customer — zero governance rework. The moat is the governance.

A console doesn't give you least-privilege intersection, a human gate withheld in code, WORM audit, per-department chargeback, or a compliance pack that survives a review board. Aegis does — and add-on agents inherit all of it for free.

DEPLOYABLE TODAY

The clean-account acceptance test

One command runs the entire governance control plane end to end — no AWS, no API key, no network. A green run is the whole pitch.



RESULT: 18/18 steps passed, 0 failed · exits non-zero if any step fails

- ✓ Deny-by-default + data-class boundary
- ✓ Consequential action withheld → human gate
- ✓ Separation of duties (no self-approval)
- ✓ Single-use approval; replay rejected
- ✓ Append-only hash-chained audit; mutation raises
- ✓ Sealed WORM evidence + masked usage ledger

CloudFormation passes cfn-lint · IaC parity (CloudFormation + Terraform, commercial + GovCloud) · the no-API-key local demo runs the full scenario in ~1s.

Generalize, don't rebuild · slg-ai-agents → Aegis

Keep (reused verbatim)

- ✓ Deny-by-default authorization gateway
- ✓ Consequential actions withheld + human gate
- ✓ Append-only audit + WORM + fail-closed masking
- ✓ In-account Bedrock + Guardrails + governed RAG
- ✓ Cryptographic identity (RS256 over JWKS)
- ✓ 8 agents as one-command SAM golden paths
- ✓ Deployed & torn down on live AWS (caught 2 bugs)
- ✓ Intellectual honesty: explicit RACI + remediation

Add (the Aegis layers)

- + Industry-agnostic core + overlay packs
- + FinOps: token caps + chargeback (AIPs)
- + Signed agent manifest + minimum-bar CI gate
- + Education + Healthcare-Life-Sciences packs
- + Automated reasoning checks (formal logic)
- + AgentCore Gateway + Policy/Cedar as control plane
- + COPPA 2025, 42 CFR Pt 2, GxP/Part 11 regimes

What's real vs. what's customer-owned

Real today (implemented & tested)

- ✓ Deny-by-default gateway + least-privilege
- ✓ Human gate: bound, single-use, SoD
- ✓ Append-only audit + WORM + masking
- ✓ In-account Bedrock + Guardrails + grounding
- ✓ Automated reasoning + contextual grounding
- ✓ Manifest + 9-point minimum-bar CI gate
- ✓ Token budgets + chargeback (AIP tags)
- ✓ IaC parity (CFN + TF, commercial + GovCloud)

Customer-owned (engagement work)

- ATO / GovRAMP / FedRAMP authorization
- Signed AWS BAA (before any PHI)
- Live connectors (fixtures today)
- Production IdP integration + MFA
- Guardrail / red-team / eval tuning
- Third-party penetration test
- Retention schedule + HITL queue staffing
- Data classification + class isolation

"HIPAA-eligible" ≠ "HIPAA-compliant." The platform implements technical controls; authorization, agreements, and operational ownership are customer responsibilities. The candor is a selling feature.

THE ASK

Start with one low-blast-radius agent.

Prove the paved road against a documented outcome — then scale agent by agent on governance that's already funded and compliant.

- 1 Discovery + architecture workshop** Map your IdP, data classes, and regimes → select packs.
- 2 Stand up the golden path** One isolated stack with synthetic data — demo the human gate, audit, masking, budget cap live.
- 3 Prove a documented outcome** e.g. self-service deflection economics or cycle-time cut on a reversible, high-volume workflow.
- 4 Sign the shared-responsibility plan** The RACI so security review has no surprises — then land-and-expand.

Opening line: "Let's build the governance once — and make every agent you ever deploy compliant by default."

A Appendix A

For the customer: CIO / CISO / Director of Architecture

The four CISO questions and their answers · control → regime matrix · the first 90 days

Four CISO questions, four answers

Q Can the AI act on its own?

No. Every consequential action is withheld from the agent in code and proven absent by a test. It executes only after a bound, single-use, separation-of-duties human approval.

Q Do you trust client-supplied roles?

Never. Identity is cryptographically verified (RS256 over the IdP JWKS, alg-confusion guard). Least-privilege is the intersection of agent grant and user entitlement.

Q Will the audit hold up?

Append-only DynamoDB (PutItem-only IAM) + S3 Object Lock WORM + fail-closed masking of PII/PHI/FTI/CJI. It survives a review board, a FOIA request, or an OIG audit.

Q Where does inference run?

In-account over PrivateLink with mandatory Guardrails on input and output. The model never receives unmasked sensitive data; no PII egress.

Control → regime matrix

	GovRAMP	CJIS v6	IRS 1075	HIPAA	GxP/P11	FERPA	COPPA	PCI	AI RMF
Edge WAF / Shield	✓	✓	✓	✓	.	.	.	✓	.
Cryptographic identity + MFA	✓	✓	✓	✓	.	✓	✓	.	✓
Deny-by-default gateway	✓	✓	✓	✓	✓	✓	✓	✓	✓
Human gate (bound, SoD)	✓	✓	✓	✓	✓	✓	.	.	✓
In-account inference + Guardrails	✓	✓	✓	✓	✓	✓	✓	.	✓
Grounding + automated reasoning	.	.	.	✓	✓	.	.	.	✓
Append-only audit + WORM	✓	✓	✓	✓	✓	✓	.	✓	✓
Masking, fail-closed	✓	✓	✓	✓	.	✓	✓	✓	✓
KMS CMK + data-class isolation	✓	✓	✓	✓	✓	✓	.	✓	✓
Token budgets + chargeback	.	.	.	.	.	.	.	.	✓
Continuous monitoring	✓	✓	✓	✓	✓	.	.	✓	✓

Summary view. Full control-by-control machine-readable mapping: [governance/controls/control_mappings.yaml](#).

The first 90 days

1

Days 0–30

Discover & design

Architecture workshop • map IdP, data classes, regimes → select packs • agree the RACI and gated go-live checklist.

2

Days 30–60

Stand up the golden path

One isolated stack (VPC, edge, Cognito, KMS, WORM, gateway, agent) with synthetic data • demo human gate, audit, masking, budget cap live.

3

Days 60–90

Prove & prepare to scale

Run evals to the declared pass rate • prove the documented outcome • build the first live connector • begin the authorization control package.

Land-and-expand: add agents one at a time on the same paved road; turn on chargeback; introduce orchestration when ≥ 2 agents are live.

Appendix B

For AWS: field & leadership

The consumption story · which services it pulls · the Marketplace add-on motion · land-and-expand

Durable consumption across the right services

Services it pulls

- **Amazon Bedrock + Guardrails** — models, grounding, automated reasoning
- **AgentCore** — Gateway / Identity / Runtime / Policy
- **AWS GovCloud (US)** — High-impact / CJ / FTI workloads
- **KMS** — CMK per data class
- **Macie / Comprehend** — sensitive-data discovery + masking
- **FinOps stack** — AIPs • Cost Explorer • CUR • Budgets
- **Edge & posture** — CloudFront/WAF/Shield • CloudTrail/GuardDuty/Config

The consumption (ACR) story

- › Durable, consumption-generating workloads — not a one-time license.
- › Accelerates regulated-industry adoption — the exact segments (gov, HCLS, education) where AWS wins on compliance breadth.
- › De-risks the customer's security review — the real blocker to Bedrock consumption in regulated accounts.
- › Converts stalled pilots into funded production — every governed agent is metered Bedrock + AgentCore spend.

Marketplace add-ons + land-and-expand

The Marketplace motion

- 1 Package** An add-on agent is packaged once as a manifest-conformant product.
- 2 List** It becomes an AWS Marketplace listing — an ISV / partner flywheel.
- 3 Deploy** It deploys onto any governed Aegis environment and inherits governance.
- 4 Compound** Every new pack opens an industry; every agent sells into every governed customer.

Land-and-expand

- **LAND** One low-blast-radius agent on the governed paved road — first metered Bedrock/AgentCore spend.
- **PROVE** A documented outcome + a clean security review — the platform is now trusted.
- **EXPAND** Add agents one at a time, zero governance rework — consumption grows per agent.
- **ORCHESTRATE** Introduce the coordination layer when ≥ 2 agents are live — whole-of-enterprise.

The differentiation: a console gives you a model. Aegis gives you a governed, compliant, chargeback-aware platform that makes Bedrock consumption safe in a regulated account.